

****November 18, 2024****

****Sanction for Non-Compliance with GDPR****

The National Supervisory Authority for Personal Data Processing completed, in October 2024, an investigation into the operator Altex România S.A. and found violations of the provisions of Article 32 paragraph (1) letter b) and Article 32 paragraph (2) of Regulation (EU) 2016/679 (GDPR).

As such, the operator was sanctioned with a fine of 99,516 lei, equivalent to 20,000 EURO.

The investigation was initiated following the fact that Altex România S.A. submitted two notifications to the National Supervisory Authority regarding the occurrence of personal data security breaches, as follows:

a) The operator was informed via email by a third party that some of the operator's customer accounts had been published on a platform, affecting personal data of a very large number of data subjects, namely: first name, last name, email, altex.ro account password, information available in the customer account, such as delivery address, phone number, order history, data related to the cards used for online payment, communications with the operator;

b) The operator found that it had been the victim of a "credential stuffing" cyber attack, through repeated attempts to validate passwords on customer accounts for placing gift card orders; it was specified that the following personal data were affected for a significantly large number of data subjects: login identification data for customer account: first name, last name, email address, customer account access password, financial data related to bank cards registered in the application/site. During the investigation, it was found that the operator Altex România S.A. had not implemented appropriate technical and organizational measures to ensure a level of security corresponding to the risk presented by the processing, in order to prevent illegal access to the operator's customer accounts. This led to unauthorized access to the personal data of a very large number of the operator's customers through two distinct cyber attacks involving the takeover of control over certain accounts. At the same time, based on Article 58 paragraph (2) letter d) of Regulation (EU) 2016/679, the following corrective measures were ordered:

- Technical and procedural implementation of the following measures to mitigate the risk of personal data confidentiality breaches through cyber attacks on authentication platforms for customer accounts on all managed e-commerce websites/applications: notification of new device login, display of logged devices in the account, complexity policy and password history for all customer accounts with a predetermined expiration interval;

- Technical and procedural implementation of a monitoring system for inbound and outbound internet traffic executed on the authentication platforms for customer accounts on all managed e-commerce websites/applications.

****Legal and Communication Department****

****N.S.A.P.D.C.P.****